

Security Incident Report

Cloudora Security Operations | Template CLD-IR-TEMPLATE | Complete every section. If a section is empty, write why.

Report ID	CLD-IR-0002
Related	
ticket	
Report title	
Analyst	
Date of report (UTC)	
Incident severity	P1 - two staff accounts compromised and actively signed into by an external attacker; live credential theft against a company that holds customer payroll data.
Status	Contained - eradication verified, monitoring continues
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

Four to five sentences a non-technical executive can read in 60 seconds: what happened, how it was found, what the attacker did, what has been done about it, and what the business risk was. No IP addresses, no query syntax, no acronyms without expansion. Write this section LAST, after everything else is filled in.

On 25th of August, 40 Cloudora staff received a payroll-themed phishing email from an attacker in Amsterdam pretending to be HR and asking recipients to 'confirm their payroll details' on a lookalike website. The campaign used two message styles: one that forged the real cloudora.io address and failed every authentication check, and one sent from a convincing lookalike domain that passed authentication for that fake domain. Six employees clicked the link and two entered their passwords. The attacker used both stolen passwords the same day, signing in to those two accounts from an address in Amsterdam. The compromise was caught the same morning after staff reported the email; both accounts were contained, the attacker's access was cut off, the sending and hosting infrastructure was blocked, and the phishing messages were purged from mailboxes. A marketing newsletter that one employee reported alongside the phish was confirmed legitimate. No fraudulent payment or data theft was found in the available logs. Four further staff who clicked but did not enter credentials, and thirty who received the email but did not click, are being contacted.

2. Incident timeline

Every significant event in order, all times in UTC. Include attacker actions, victim actions, and response actions. Cite the log source for each row - a timeline entry you cannot evidence does not belong here.

Time (UTC)	Source	Event	Evidence / notes
Aug 25, 06:58	Msg trace	Legitimate Cloudora newsletter delivered via Mailchimp	later reported, cleared as a false positive
Aug 25, 08:04-08:20	Msg trace	Phishing variant A, wave 1, sent from 198.18.44.10 spoofing payroll@cloudora.io; SPF/DKIM/DMARC fail; some copies quarantined by EOP, some delivered	
Aug 25, 08:35-08:50	Msg trace	seth.lane clicks the variant A link; no credentials submitted	
Aug 25, 08:47:12	Msg trace	freya.lynn clicks variant A and SUBMITS credentials	
Aug 25, 09:05:44	Msg trace	ryan.boyd clicks variant B and SUBMITS credentials	
Aug 25, 09:11	Ticket	Ticket	
Aug 25, 09:58 / 10:12 / 11:47	Msg trace	hugo.marsh, chloe.price and dina.said click the link; none submit credentials	
Aug 25, 10:34:20	Sign-in	Attacker signs in as freya.lynn from 198.18.7.200 (Amsterdam, NL) on Windows 11 / Chrome - harvested credential used (T1078); Outlook Web 10:36, SharePoint 10:41	

Aug 25, 13:22:05	Sign-in	Attacker signs in as ryan.boyd from 198.18.7.200 (Amsterdam) - second account used; Outlook Web 13:25	
Aug 25, ~14:00	Response	Containment executed on both accounts (see section 7)	

3. Findings

One numbered finding per distinct fact you established. State the finding in one sentence, then the evidence (which query, which rows), then why it matters. Findings are facts, not guesses - if you are inferring, say so.

Finding 1

On 25 August, 40 Cloudora mailboxes were targeted by a phishing campaign with the subject lines 'Payroll update: action required before 5pm' and Action required: confirm your August payroll details', both impersonating Cloudora HR and linking to cloudora-hr-portal.example, a lookalike of cloudora.io. Exchange Online Protection quarantined every copy sent to 4 recipients; 36 recipients had at least one copy delivered to the inbox. Evidence: CloudoraMsgTrace_CL delivery events, and the reported .eml files

Finding 2

Variant A forged the real address payroll@cloudora.io and failed SPF, DKIM and DMARC (compauth=fail), sent from 198.18.44.10 and 198.18.44.23. Variant B was sent from the attacker's own lookalike domain cloudora-hr-portal.example (198.18.51.7) and PASSED SPF, DKIM and DMARC - but for the lookalike domain, not for Cloudora. Authentication only proves the sending domain, not its legitimacy; both variants are malicious. This is the same test that clears the false positive in Finding 6.

Finding 3

freya.lynn@cloudora.io and ryan.boyd@cloudora.io both clicked and submitted credentials (CloudoraMsgTrace_CL click events at 08:47 and 09:05, CredentialsSubmitted = Yes). Both were then signed into from 198.18.7.200 (Amsterdam, Netherlands) on a Windows 11 / Chrome device never seen on their accounts: Freya at 10:34 (impossible travel against her genuine Manchester sign-ins that morning), Ryan at 13:22. The attacker accessed Outlook Web and, for Freya, SharePoint Online. This is use of harvested valid credentials (T1078)

Finding 4

seth.lane, chloe.price, hugo.marsh and dina.said clicked the phishing link (CredentialsSubmitted = No) and show no anomalous sign-in in the logs. They are not confirmed compromised, but a click means they reached the harvesting page; they are treated as elevated risk pending a precautionary password reset and a direct check-in.

4. Indicators of compromise (IOCs)

Everything another analyst would need to detect or block this attacker: IP addresses, device names, rule names, user agents. One row per indicator, with where you found it.

Type	Value	First seen (UTC)	Context
Domain	cloudora-hr-portal.example		Lookalike of cloudora.io; phishing / credential harvesting; subdomains mail., mailer., login.
URL	hxxps://cloudora-hr-portal[.]example/payroll/login		Variant A harvesting link (defanged)
URL	hxxps://login.cloudora-hr-portal[.]example/verify		Variant B harvesting link (defanged)
IPv4	198.18.44.10		Variant A wave-1 sending relay + harvest host (Amsterdam, synthetic)
IPv4	198.18.44.23		Variant A wave-2 sending relay (same /24)
IPv4	198.18.51.7		Variant B sending relay
Sender	payroll@cloudora.io (spoofed)		Forged From on variant A; Reply-To hr-support@cloudora-hr-portal.example
Sender	payroll@cloudora-hr-portal.example		Variant B From (lookalike domain)
Subject	Payroll update: action required before 5pm		Variant A
Subject	Action required: confirm your August payroll details		Variant B

5. MITRE ATT&CK; mapping

Map each attacker behaviour you observed to a technique. Use the technique ID (e.g. T1110.003) and name, and point to the finding that evidences it. Only map what you actually saw in the logs.

Tactic	Technique ID	Technique name	Evidenced by
Initial Access	T1566.002	Phishing: Spearphishing Link	Findings 1-2, the two phishing variants and their links
Credential Access	T1598.003	Phishing for Information: Spearphishing Link	The credential-harvesting page behind the link
Initial Access	T1078.004	Valid Accounts: Cloud Accounts	Finding 3, attacker sign-ins with harvested credentials
Acquire infrastructure	T1583.001	Context technique	The attacker registered and hosted a lookalike domain

6. Scope

Who and what was affected. List: (a) accounts confirmed compromised, (b) accounts targeted but not breached, (c) accounts investigated and cleared, with the evidence for each. If you have not checked scope, the incident is not scoped - say so explicitly.

Accounts confirmed compromised (2)

freya.lynn@cloudora.io (attacker sign-in 10:34:20 UTC) and ryan.boyd@cloudora.io (13:22:05 UTC), both 25 Aug, both from 198.18.7.200; both submitted credentials to the phishing page.

Accounts clicked but not confirmed compromised (4)

seth.lane, chloe.price, hugo.marsh, dina.said - clicked the link, no credentials submitted, no anomalous sign-in. Precautionary reset and direct check-in.

Accounts targeted but not breached (34)

Thirty received the phish and did not click (near-miss, user comms). Four more (emma.hayes, maya.chen, nina.cole, ruth.dean) had every copy quarantined by EOP.

Accounts investigated and cleared (false positives) (1)

The 'Cloudora Monthly' Mailchimp newsletter - legitimate marketing mail (Finding 6).

7. Actions taken

What was actually done, by whom, at what time (UTC), in order. Containment first (stop the bleeding), then eradication (remove attacker access and persistence), then verification (prove it worked). An action without a timestamp did not happen.

Time (UTC)	Action	Performed by	Verified how
	Revoked all active sessions and refresh tokens for freya.lynn and ryan.boyd	Khaled Sharafeddin	Verified: re-ran the victim sign-in and attacker-IP pivot queries; no 198.18.7.200 activity after containment
	Reset credentials for both compromised accounts	Khaled Sharafeddin	Verified: re-ran the victim sign-in and attacker-IP pivot queries; no 198.18.7.200 activity after containment
	Required and re-registered MFA on both accounts	Khaled Sharafeddin	Verified: re-ran the victim sign-in and attacker-IP pivot queries; no 198.18.7.200 activity after containment
	Blocked infrastructure: 198.18.44.10, 198.18.44.23, 198.18.51.7, 198.18.7.200 and cloudora-hr-portal.example (all subdomains) at mail gateway and web proxy	Khaled Sharafeddin	Verified: re-ran the victim sign-in and attacker-IP pivot queries; no 198.18.7.200 activity after containment
	Purged delivered phishing messages from all mailboxes (soft delete / ZAP)	Khaled Sharafeddin	Verified: re-ran the victim sign-in and attacker-IP pivot queries; no 198.18.7.200 activity after containment
	Verified: re-ran the victim sign-in and attacker-IP pivot queries; no 198.18.7.200 activity after containment	Khaled Sharafeddin	Verified: re-ran the victim sign-in and attacker-IP pivot queries; no

		198.18.7.200 activity after containment
--	--	---

8. Recommendations

What the client should change so this attack fails next time. Be specific and prioritised: quick wins first, then strategic changes. Every recommendation should trace back to a finding.

- Precautionary password resets and a direct check-in for the four clicked-but-no-credential staff; user communications and awareness for the thirty near-miss recipients (see the client comms draft in the answer key).
- Enforce MFA on all accounts and disable legacy authentication that bypasses it; both compromises were password-only.
- Move cloudora.io DMARC policy to p=reject so spoofing variants like variant A are rejected outright, not merely quarantined, and downstream recipients reject them too.
- Add mail-gateway detection for newly-registered lookalike domains and for external mail whose From is cloudora.io but which fails DMARC.
- Deploy the sign-in detection from Task 4: a successful sign-in from a new country within a few hours of a phishing-link click. This would have flagged both compromises the same morning.
- Block the phishing infrastructure permanently and monitor for the actor re-registering adjacent lookalike domains.

9. Lessons learned

What worked in this investigation, what was slow or missing, and what the SOC should do differently. This section is about the response, not the attacker.

Staff reporting caught this: the first forwarded email opened the ticket before automatic detection did, which argues for keeping the report button prominent and praised. The message trace turned a single reported email into full campaign scope in minutes, and pivoting on the attacker's sign-in IP surfaced the second victim immediately. The false positive mattered as much as the phish: variant B and the Mailchimp newsletter both pass authentication, and only checking which domain they pass for tells them apart. The gap to close is detection speed: both compromises were visible in the logs within an hour of the clicks, and a click-then-foreign-login rule would have alerted automatically rather than waiting on a human report.

Template notes: keep all times UTC; write findings as you work, not at the end; the executive summary is written last but appears first. Completed example for this scenario: report CLD-IR-0001.